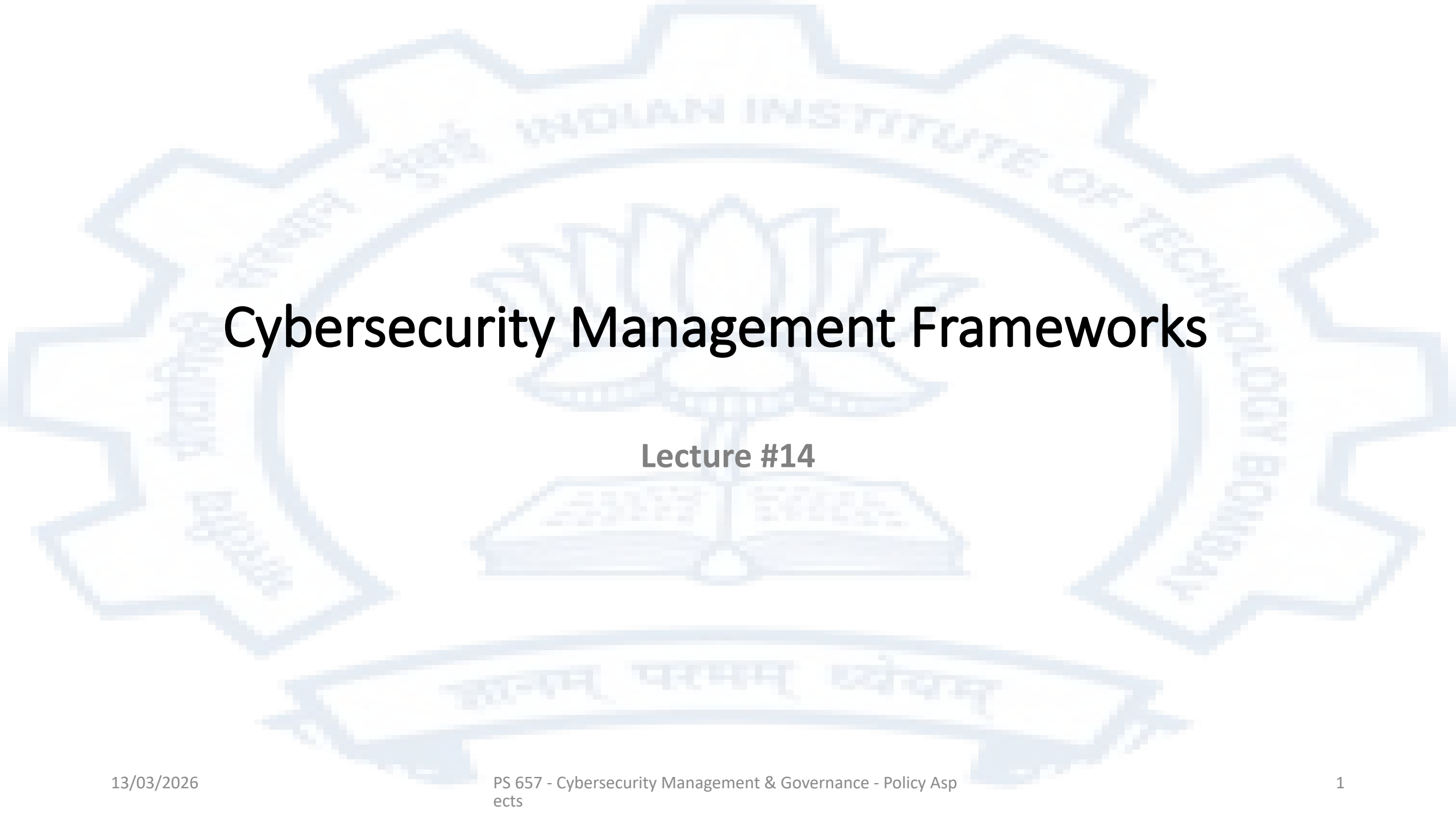
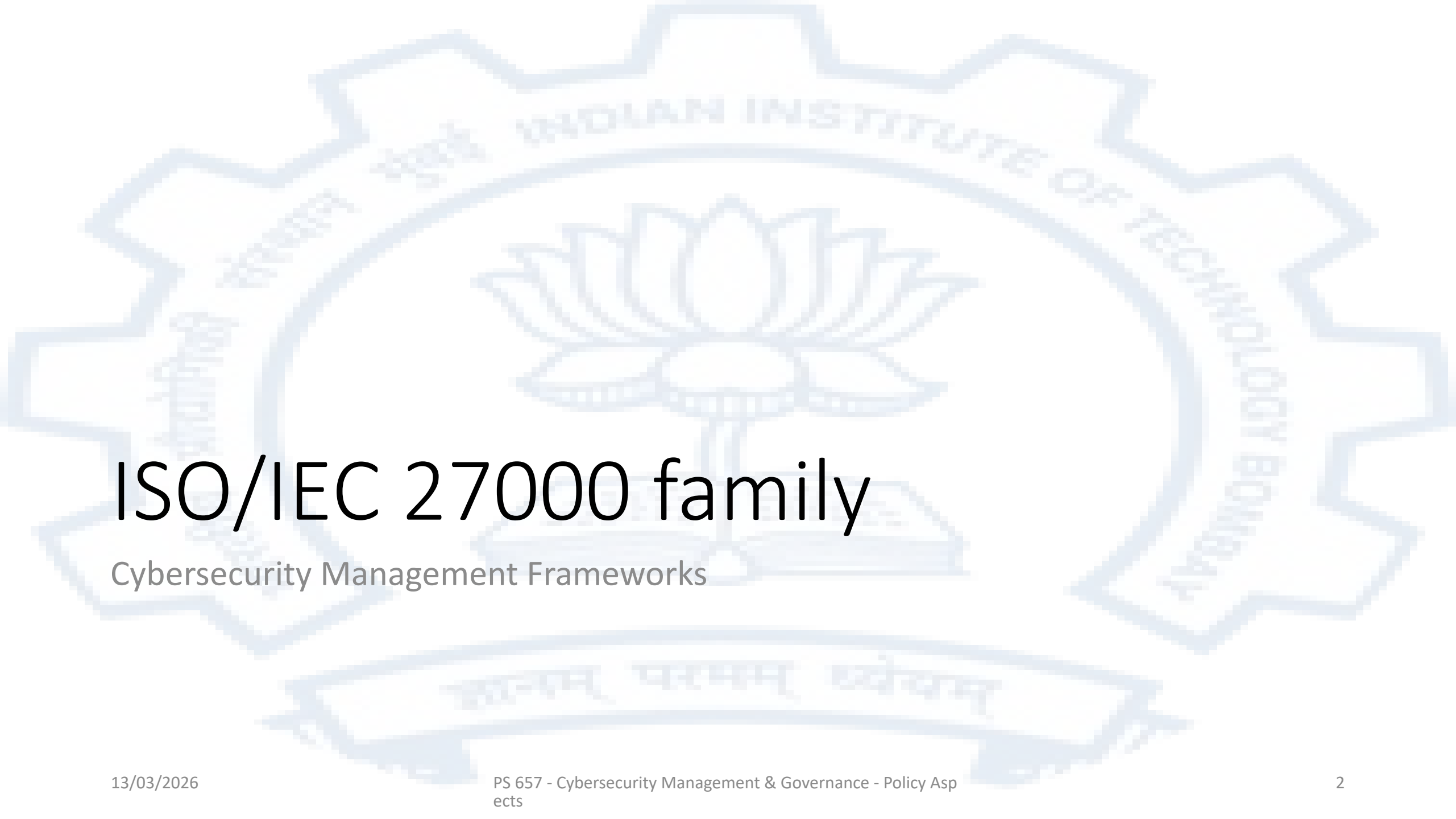


The background of the slide features a large, light blue watermark of the Indian Institute of Technology Bombay logo. The logo is a gear-like shape with a central emblem containing a lotus flower and an open book. The text "INDIAN INSTITUTE OF TECHNOLOGY BOMBAY" is written in a circular path around the central emblem, and a banner at the bottom contains text in Sanskrit.

Cybersecurity Management Frameworks

Lecture #14

The background of the slide features a large, light blue watermark of the Indian Institute of Technology Bombay logo. The logo is a gear-like shape with a lotus flower in the center. The text "INDIAN INSTITUTE OF TECHNOLOGY BOMBAY" is written in a circular path around the lotus. At the bottom, there is a banner with the Sanskrit motto "सत्यमेव जयते" (Satyameva Jayate).

ISO/IEC 27000 family

Cybersecurity Management Frameworks

Overview of the ISO/IEC 27000 series of standards

ISO/IEC 27000:2018(E)

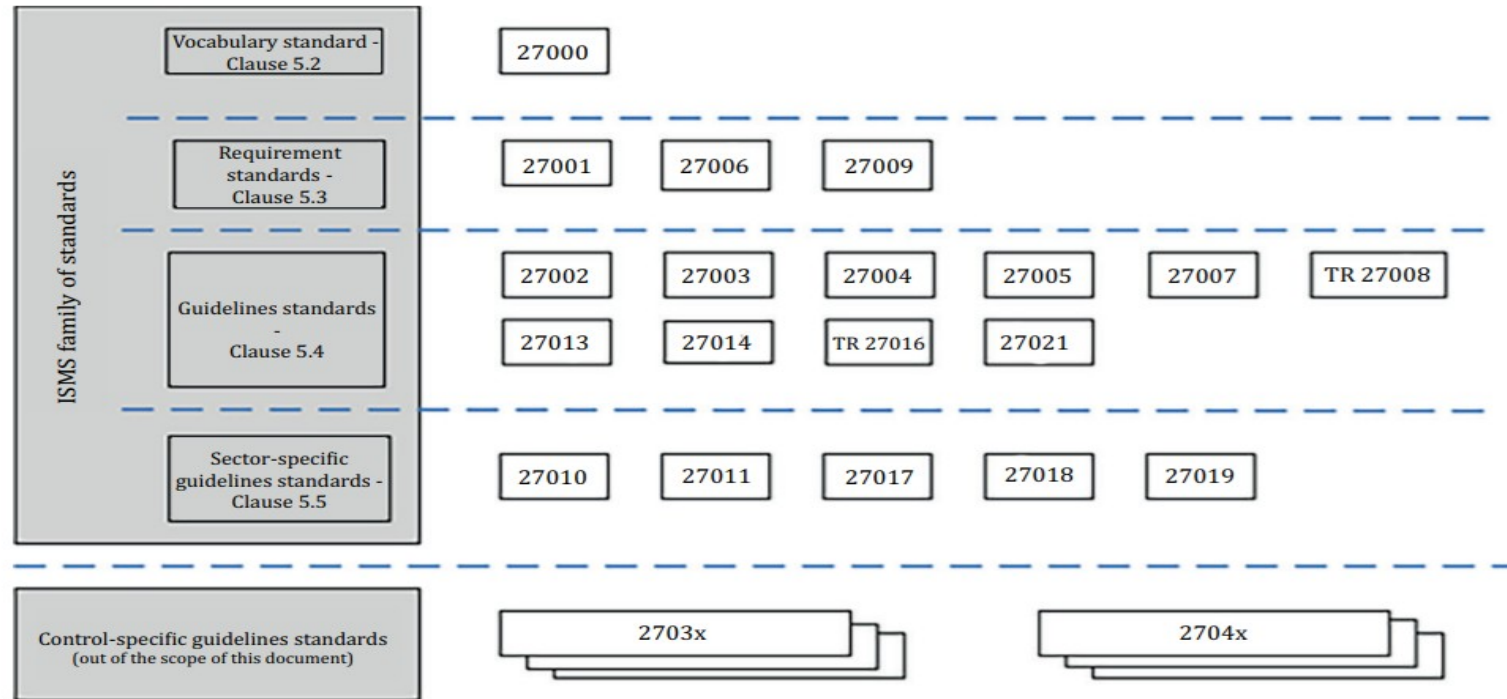


Figure 1 — ISMS family of standards relationships

Vocabulary standards v/s requirements standards

A ***vocabulary standard*** establishes a common and consistent set of terms and concepts within a specific field that can be used to ensure clear and unambiguous communication.

A ***requirements standards*** describes a set of requirements (criteria, expectations etc.) that a product, service or process needs to satisfy in order to be considered adequate, acceptable or compliant. Certification always happens against a requirements standard.

What is an ISMS (Information Security Management System) – as described in ISO/IEC 27000 : 2018(E)

4.2.1 Overview and principles

An ISMS consists of the policies, procedures, guidelines, and associated resources and activities, collectively managed by an organization, in the pursuit of protecting its information assets. An ISMS is a systematic approach for establishing, implementing, operating, monitoring, reviewing, maintaining and improving an organization's information security to achieve business objectives. It is based on a risk assessment and the organization's risk acceptance levels designed to effectively treat and manage risks. Analysing requirements for the protection of information assets and applying appropriate controls to ensure the protection of these information assets, as required, contributes to the successful implementation of an ISMS. The following fundamental principles also contribute to the successful implementation of an ISMS:

- a) awareness of the need for information security;
- b) assignment of responsibility for information security;
- c) incorporating management commitment and the interests of stakeholders;
- d) enhancing societal values;
- e) risk assessments determining appropriate controls to reach acceptable levels of risk;
- f) security incorporated as an essential element of information networks and systems;
- g) active prevention and detection of information security incidents;
- h) ensuring a comprehensive approach to information security management;
- i) continual reassessment of information security and making of modifications as appropriate.

ISO/IEC 27001:2022- Information technology — Security techniques — Information security management systems — Requirements

Scope: This document specifies the requirements for establishing, implementing, maintaining and continually improving an information security management system within the context of the organization. This document also includes requirements for the assessment and treatment of information security risks tailored to the needs of the organization. The requirements set out in this document are generic and are intended to be applicable to all organizations, regardless of type, size or nature. Excluding any of the requirements specified in [Clauses 4](#) to [10](#) is not acceptable when an organization claims conformity to this document.

Structure of ISO/IEC 27001:2022

- This standard defines the requirements for an ISMS (Information Security Management System)
- It has two major components
 - The main body of the standard that describes
 - How to define the scope of the entity for which the ISMS is being built
 - What the major aspects of an ISMS are
 - Annex A
 - Is a list of specific controls that are required to be implemented

ISO/IEC 27001:2022 – characterizing an ISMS

- Clause 4 – Context of the organization
- Clause 5 – Leadership
- Clause 6 – Planning
- Clause 7 - Support
- Clause 8 – Operation
- Clause 9 – Performance evaluation
- Clause 10 - Improvement

The background of the slide features a large, light blue watermark of the Indian Institute of Technology Bombay logo. The logo is a gear-like shape with a lotus flower in the center. The text "INDIAN INSTITUTE OF TECHNOLOGY BOMBAY" is written in a circular path around the lotus. At the bottom of the logo, there is a banner with the Sanskrit motto "वैद्यमान् परममन् व्योमन्".

ISO/IEC 27001:2022(E) Controls

Annex - A

Organizational Controls

Table A.1 — Information security controls

5	Organizational controls	
5.1	Policies for information security	Control Information security policy and topic-specific policies shall be defined, approved by management, published, communicated to and acknowledged by relevant personnel and relevant interested parties, and reviewed at planned intervals and if significant changes occur.
5.2	Information security roles and responsibilities	Control Information security roles and responsibilities shall be defined and allocated according to the organization needs.
5.3	Segregation of duties	Control Conflicting duties and conflicting areas of responsibility shall be segregated.
5.4	Management responsibilities	Control Management shall require all personnel to apply information security in accordance with the established information security policy, topic-specific policies and procedures of the organization.
5.5	Contact with authorities	Control The organization shall establish and maintain contact with relevant authorities.
5.6	Contact with special interest groups	Control The organization shall establish and maintain contact with special interest groups or other specialist security forums and professional associations.
5.7	Threat intelligence	Control Information relating to information security threats shall be collected and analysed to produce threat intelligence.
5.8	Information security in project management	Control Information security shall be integrated into project management.
5.9	Inventory of information and other associated assets	Control An inventory of information and other associated assets, including owners, shall be developed and maintained.
5.10	Acceptable use of information and other associated assets	Control Rules for the acceptable use and procedures for handling information and other associated assets shall be identified, documented and implemented.
5.11	Return of assets	Control Personnel and other interested parties as appropriate shall return all the organization's assets in their possession upon change or termination of their employment, contract or agreement.

Organizational Controls

cont- 1

Table A.1 (continued)

5.12	Classification of information	Control Information shall be classified according to the information security needs of the organization based on confidentiality, integrity, availability and relevant interested party requirements.
5.13	Labelling of information	Control An appropriate set of procedures for information labelling shall be developed and implemented in accordance with the information classification scheme adopted by the organization.
5.14	Information transfer	Control Information transfer rules, procedures, or agreements shall be in place for all types of transfer facilities within the organization and between the organization and other parties.
5.15	Access control	Control Rules to control physical and logical access to information and other associated assets shall be established and implemented based on business and information security requirements.
5.16	Identity management	Control The full life cycle of identities shall be managed.
5.17	Authentication information	Control Allocation and management of authentication information shall be controlled by a management process, including advising personnel on appropriate handling of authentication information.
5.18	Access rights	Control Access rights to information and other associated assets shall be provisioned, reviewed, modified and removed in accordance with the organization's topic-specific policy on and rules for access control.
5.19	Information security in supplier relationships	Control Processes and procedures shall be defined and implemented to manage the information security risks associated with the use of supplier's products or services.
5.20	Addressing information security within supplier agreements	Control Relevant information security requirements shall be established and agreed with each supplier based on the type of supplier relationship.
5.21	Managing information security in the information and communication technology (ICT) supply chain	Control Processes and procedures shall be defined and implemented to manage the information security risks associated with the ICT products and services supply chain.
5.22	Monitoring, review and change management of supplier services	Control The organization shall regularly monitor, review, evaluate and manage change in supplier information security practices and service delivery.
5.23	Information security for use of cloud services	Control Processes for acquisition, use, management and exit from cloud services shall be established in accordance with the organization's information security requirements.
5.24	Information security incident management planning and preparation	Control The organization shall plan and prepare for managing information security incidents by defining, establishing and communicating information security incident management processes, roles and responsibilities.

Organizational Controls cont- 2

Table A.1 (continued)

5.25	Assessment and decision on information security events	Control The organization shall assess information security events and decide if they are to be categorized as information security incidents.
5.26	Response to information security incidents	Control Information security incidents shall be responded to in accordance with the documented procedures.
5.27	Learning from information security incidents	Control Knowledge gained from information security incidents shall be used to strengthen and improve the information security controls.
5.28	Collection of evidence	Control The organization shall establish and implement procedures for the identification, collection, acquisition and preservation of evidence related to information security events.
5.29	Information security during disruption	Control The organization shall plan how to maintain information security at an appropriate level during disruption.
5.30	ICT readiness for business continuity	Control ICT readiness shall be planned, implemented, maintained and tested based on business continuity objectives and ICT continuity requirements.
5.31	Legal, statutory, regulatory and contractual requirements	Control Legal, statutory, regulatory and contractual requirements relevant to information security and the organization's approach to meet these requirements shall be identified, documented and kept up to date.
5.32	Intellectual property rights	Control The organization shall implement appropriate procedures to protect intellectual property rights.
5.33	Protection of records	Control Records shall be protected from loss, destruction, falsification, unauthorized access and unauthorized release.
5.34	Privacy and protection of personal identifiable information (PII)	Control The organization shall identify and meet the requirements regarding the preservation of privacy and protection of PII according to applicable laws and regulations and contractual requirements.
5.35	Independent review of information security	Control The organization's approach to managing information security and its implementation including people, processes and technologies shall be reviewed independently at planned intervals, or when significant changes occur.
5.36	Compliance with policies, rules and standards for information security	Control Compliance with the organization's information security policy, topic-specific policies, rules and standards shall be regularly reviewed.
5.37	Documented operating procedures	Control Operating procedures for information processing facilities shall be documented and made available to personnel who need them.

People Controls

Table A.1 (continued)

6	People controls	
6.1	Screening	Control Background verification checks on all candidates to become personnel shall be carried out prior to joining the organization and on an ongoing basis taking into consideration applicable laws, regulations and ethics and be proportional to the business requirements, the classification of the information to be accessed and the perceived risks.
6.2	Terms and conditions of employment	Control The employment contractual agreements shall state the personnel's and the organization's responsibilities for information security.
6.3	Information security awareness, education and training	Control Personnel of the organization and relevant interested parties shall receive appropriate information security awareness, education and training and regular updates of the organization's information security policy, topic-specific policies and procedures, as relevant for their job function.
6.4	Disciplinary process	Control A disciplinary process shall be formalized and communicated to take actions against personnel and other relevant interested parties who have committed an information security policy violation.
6.5	Responsibilities after termination or change of employment	Control Information security responsibilities and duties that remain valid after termination or change of employment shall be defined, enforced and communicated to relevant personnel and other interested parties.
6.6	Confidentiality or non-disclosure agreements	Control Confidentiality or non-disclosure agreements reflecting the organization's needs for the protection of information shall be identified, documented, regularly reviewed and signed by personnel and other relevant interested parties.
6.7	Remote working	Control Security measures shall be implemented when personnel are working remotely to protect information accessed, processed or stored outside the organization's premises.
6.8	Information security event reporting	Control The organization shall provide a mechanism for personnel to report observed or suspected information security events through appropriate channels in a timely manner.

Physical Controls

7	Physical controls	
7.1	Physical security perimeters	Control Security perimeters shall be defined and used to protect areas that contain information and other associated assets.
7.2	Physical entry	Control Secure areas shall be protected by appropriate entry controls and access points.
7.3	Securing offices, rooms and facilities	Control Physical security for offices, rooms and facilities shall be designed and implemented.
7.4	Physical security monitoring	Control Premises shall be continuously monitored for unauthorized physical

Table A.1 (continued)

7.5	Protecting against physical and environmental threats	Control Protection against physical and environmental threats, such as natural disasters and other intentional or unintentional physical threats to infrastructure shall be designed and implemented.
7.6	Working in secure areas	Control Security measures for working in secure areas shall be designed and implemented.
7.7	Clear desk and clear screen	Control Clear desk rules for papers and removable storage media and clear screen rules for information processing facilities shall be defined and appropriately enforced.
7.8	Equipment siting and protection	Control Equipment shall be sited securely and protected.
7.9	Security of assets off-premises	Control Off-site assets shall be protected.
7.10	Storage media	Control Storage media shall be managed through their life cycle of acquisition, use, transportation and disposal in accordance with the organization's classification scheme and handling requirements.
7.11	Supporting utilities	Control Information processing facilities shall be protected from power failures and other disruptions caused by failures in supporting utilities.
7.12	Cabling security	Control Cables carrying power, data or supporting information services shall be protected from interception, interference or damage.
7.13	Equipment maintenance	Control Equipment shall be maintained correctly to ensure availability, integrity and confidentiality of information.
7.14	Secure disposal or re-use of equipment	Control Items of equipment containing storage media shall be verified to ensure that any sensitive data and licensed software has been removed or securely overwritten prior to disposal or re-use.

Technological Controls

8	Technological controls	
8.1	User end point devices	Control Information stored on, processed by or accessible via user end point devices shall be protected.
8.2	Privileged access rights	Control The allocation and use of privileged access rights shall be restricted and managed.
8.3	Information access restriction	Control Access to information and other associated assets shall be restricted in accordance with the established topic-specific policy on access control.
8.4	Access to source code	Control Read and write access to source code, development tools and software libraries shall be appropriately managed.

Technological Controls cont- 1

Table A.1 (continued)

8.5	Secure authentication	Control Secure authentication technologies and procedures shall be implemented based on information access restrictions and the topic-specific policy on access control.
8.6	Capacity management	Control The use of resources shall be monitored and adjusted in line with current and expected capacity requirements.
8.7	Protection against malware	Control Protection against malware shall be implemented and supported by appropriate user awareness.
8.8	Management of technical vulnerabilities	Control Information about technical vulnerabilities of information systems in use shall be obtained, the organization's exposure to such vulnerabilities shall be evaluated and appropriate measures shall be taken.
8.9	Configuration management	Control Configurations, including security configurations, of hardware, software, services and networks shall be established, documented, implemented, monitored and reviewed.
8.10	Information deletion	Control Information stored in information systems, devices or in any other storage media shall be deleted when no longer required.
8.11	Data masking	Control Data masking shall be used in accordance with the organization's topic-specific policy on access control and other related topic-specific policies, and business requirements, taking applicable legislation into consideration.
8.12	Data leakage prevention	Control Data leakage prevention measures shall be applied to systems, networks and any other devices that process, store or transmit sensitive information.
8.13	Information backup	Control Backup copies of information, software and systems shall be maintained and regularly tested in accordance with the agreed topic-specific policy on backup.
8.14	Redundancy of information processing facilities	Control Information processing facilities shall be implemented with redundancy sufficient to meet availability requirements.
8.15	Logging	Control Logs that record activities, exceptions, faults and other relevant events shall be produced, stored, protected and analysed.
8.16	Monitoring activities	Control Networks, systems and applications shall be monitored for anomalous behaviour and appropriate actions taken to evaluate potential information security incidents.
8.17	Clock synchronization	Control The clocks of information processing systems used by the organization shall be synchronized to approved time sources.

Technological Controls cont- 2

Table A.1 (continued)

8.18	Use of privileged utility programs	Control The use of utility programs that can be capable of overriding system and application controls shall be restricted and tightly controlled.
8.19	Installation of software on operational systems	Control Procedures and measures shall be implemented to securely manage software installation on operational systems.
8.20	Networks security	Control Networks and network devices shall be secured, managed and controlled to protect information in systems and applications.
8.21	Security of network services	Control Security mechanisms, service levels and service requirements of network services shall be identified, implemented and monitored.
8.22	Segregation of networks	Control Groups of information services, users and information systems shall be segregated in the organization's networks.
8.23	Web filtering	Control Access to external websites shall be managed to reduce exposure to malicious content.
8.24	Use of cryptography	Control Rules for the effective use of cryptography, including cryptographic key management, shall be defined and implemented.
8.25	Secure development life cycle	Control Rules for the secure development of software and systems shall be established and applied.
8.26	Application security requirements	Control Information security requirements shall be identified, specified and approved when developing or acquiring applications.
8.27	Secure system architecture and engineering principles	Control Principles for engineering secure systems shall be established, documented, maintained and applied to any information system development activities.
8.28	Secure coding	Control Secure coding principles shall be applied to software development.
8.29	Security testing in development and acceptance	Control Security testing processes shall be defined and implemented in the development life cycle.
8.30	Outsourced development	Control The organization shall direct, monitor and review the activities related to outsourced system development.
8.31	Separation of development, test and production environments	Control Development, testing and production environments shall be separated and secured.
8.32	Change management	Control Changes to information processing facilities and information systems shall be subject to change management procedures.
8.33	Test information	Control Test information shall be appropriately selected, protected and managed.

Problems with ISO/IEC 27000

- It is comprehensive
- It is probably the most widely deployed framework
- It is certifiable
- There are two main drawbacks
 - It is management oriented and its structure does not reflect what cybersecurity operations should look like
 - It is expensive to implement since there are very many requirements



The NIST Cybersecurity Framework

Cybersecurity Management Frameworks

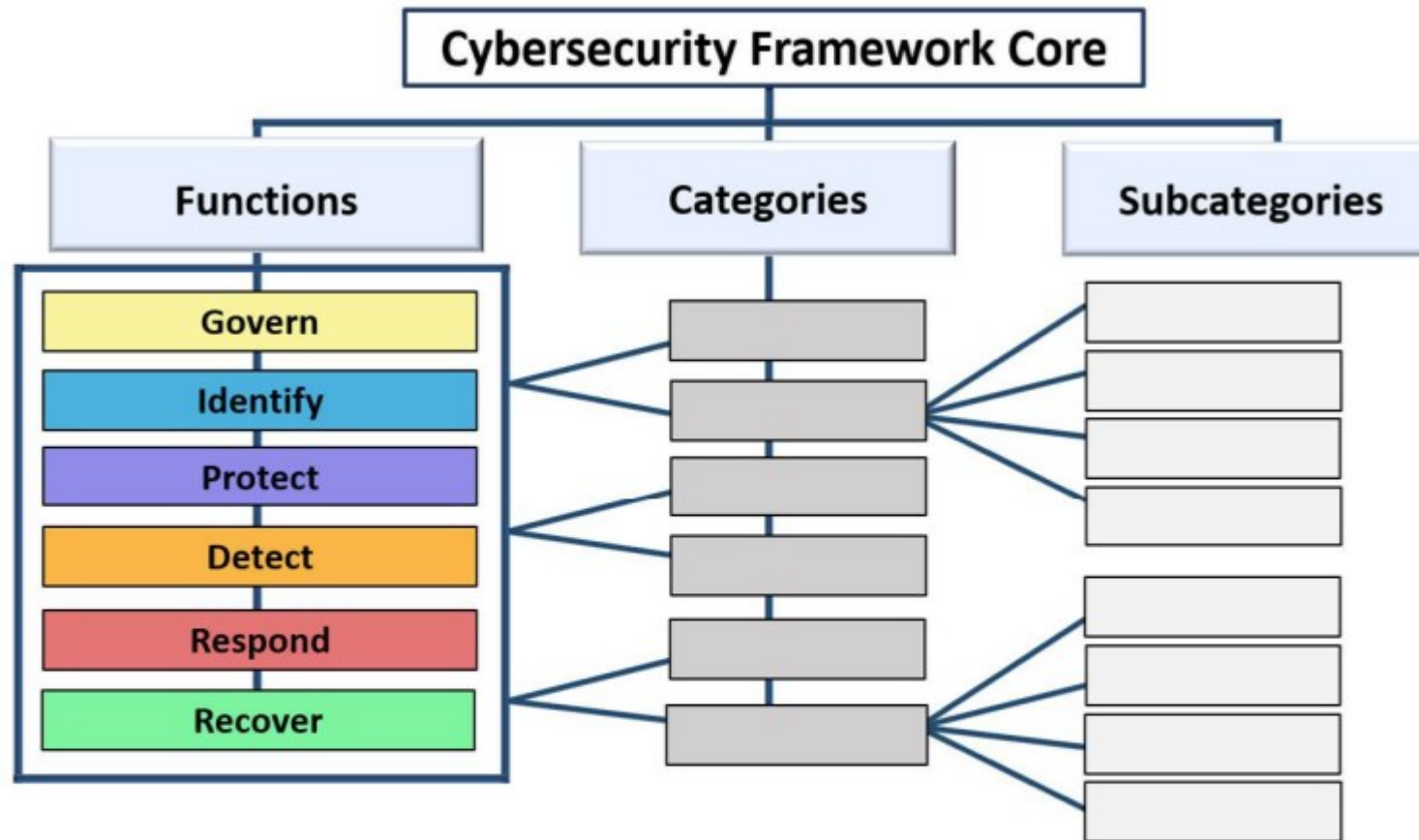


Fig. 1. CSF Core structure

The CSF Core Functions — GOVERN, IDENTIFY, PROTECT, DETECT, RESPOND, and RECOVER — organize cybersecurity outcomes at their highest level.

Govern

The organization's cybersecurity risk management strategy, expectations, and policy are established, communicated, and monitored. The GOVERN Function provides outcomes to inform what an organization may do to achieve and prioritize the outcomes of the other five Functions in the context of its mission and stakeholder expectations. Governance activities are critical for incorporating cybersecurity into an organization's broader enterprise risk management (ERM) strategy. GOVERN addresses an understanding of organizational context; the establishment of cybersecurity strategy and cybersecurity supply chain risk management; roles, responsibilities, and authorities; policy; and the oversight of cybersecurity strategy.

Identify

The organization's current cybersecurity risks are understood. Understanding the organization's assets (e.g., data, hardware, software, systems, facilities, services, people), suppliers, and related cybersecurity risks enables an organization to prioritize its efforts consistent with its risk management strategy and the mission needs identified under GOVERN. This Function also includes the identification of improvement opportunities for the organization's policies, plans, processes, procedures, and practices that support cybersecurity risk management to inform efforts under all six Functions.

Protect

Safeguards to manage the organization's cybersecurity risks are used. Once assets and risks are identified and prioritized, PROTECT supports the ability to secure those assets to prevent or lower the likelihood and impact of adverse cybersecurity events, as well as to increase the likelihood and impact of taking advantage of opportunities. Outcomes covered by this Function include identity management, authentication, and access control; awareness and training; data security; platform security (i.e., securing the hardware, software, and services of physical and virtual platforms); and the resilience of technology infrastructure.

Detect

Possible cybersecurity attacks and compromises are found and analyzed. DETECT enables the timely discovery and analysis of anomalies, indicators of compromise, and other potentially adverse events that may indicate that cybersecurity attacks and incidents are occurring. This Function supports successful incident response and recovery activities.

Respond

Actions regarding a detected cybersecurity incident are taken. RESPOND supports the ability to contain the effects of cybersecurity incidents. Outcomes within this Function cover incident management, analysis, mitigation, reporting, and communication.

Recover

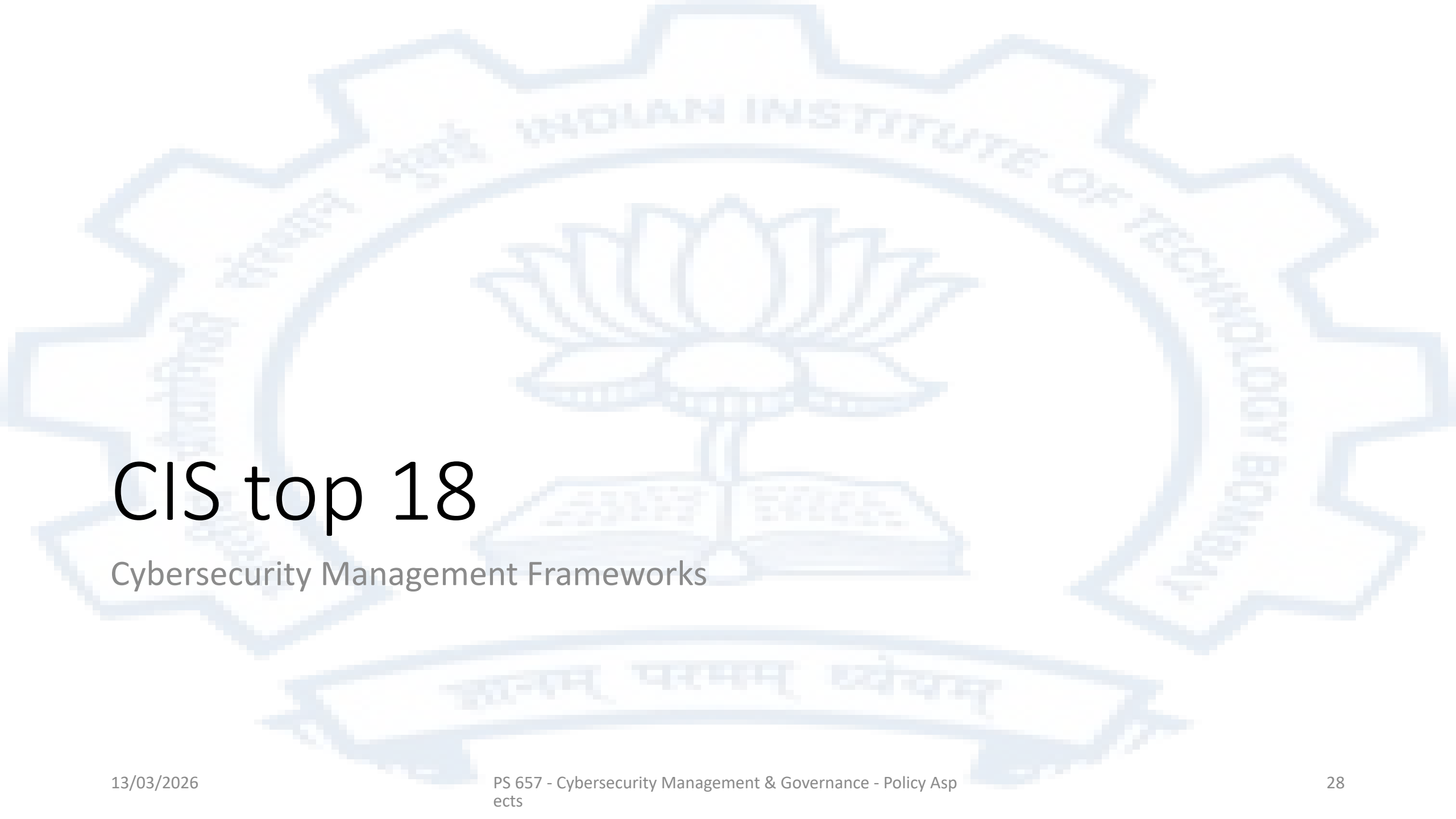
Assets and operations affected by a cybersecurity incident are restored. RECOVER supports the timely restoration of normal operations to reduce the effects of cybersecurity incidents and enable appropriate communication during recovery efforts.

NIST Cybersecurity Framework Tiers



Fig. 4. CSF Tiers for cybersecurity risk governance and management

NIST CSF adopts a maturity approach as opposed to ISO/IEC 27000 which adopts a conformity approach. When using the NIST framework an organization can be at some tier and try and progress to a higher tier. With ISO/IEC 27001 an organization either conforms or does not.

The background of the slide features a large, light blue watermark of the Indian Institute of Technology Bombay logo. The logo is a gear-like shape with a lotus flower in the center. The text "INDIAN INSTITUTE OF TECHNOLOGY BOMBAY" is written along the top inner edge of the gear, and a Sanskrit motto is at the bottom.

CIS top 18

Cybersecurity Management Frameworks

CONTROL 01 Inventory and Control of Enterprise Assets 5 Safeguards 101 2/5 102 4/5 103 5/5	CONTROL 02 Inventory and Control of Software Assets 7 Safeguards 101 3/7 102 6/7 103 7/7	CONTROL 03 Data Protection 14 Safeguards 101 6/14 102 12/14 103 14/14
CONTROL 04 Secure Configuration of Enterprise Assets and Software 12 Safeguards 101 7/12 102 11/12 103 12/12	CONTROL 05 Account Management 6 Safeguards 101 4/6 102 6/6 103 6/6	CONTROL 06 Access Control Management 8 Safeguards 101 5/8 102 7/8 103 8/8
CONTROL 07 Continuous Vulnerability Management 7 Safeguards 101 4/7 102 7/7 103 7/7	CONTROL 08 Audit Log Management 12 Safeguards 101 3/12 102 11/12 103 12/12	CONTROL 09 Email and Web Browser Protections 7 Safeguards 101 2/7 102 6/7 103 7/7
CONTROL 10 Malware Defenses 7 Safeguards 101 3/7 102 7/7 103 7/7	CONTROL 11 Data Recovery 5 Safeguards 101 4/5 102 5/5 103 5/5	CONTROL 12 Network Infrastructure Management 8 Safeguards 101 1/8 102 7/8 103 8/8
CONTROL 13 Network Monitoring and Defense 11 Safeguards 101 0/11 102 6/11 103 11/11	CONTROL 14 Security Awareness and Skills Training 9 Safeguards 101 8/9 102 9/9 103 9/9	CONTROL 15 Service Provider Management 7 Safeguards 101 1/7 102 4/7 103 7/7
CONTROL 16 Applications Software Security 14 Safeguards 101 0/14 102 11/14 103 14/14	CONTROL 17 Incident Response Management 9 Safeguards 101 3/9 102 8/9 103 9/9	CONTROL 18 Penetration Testing 5 Safeguards 101 0/5 102 3/5 103 5/5

The CIS Critical Security Controls (CIS Controls) are a prescriptive, prioritized, and simplified set of best practices that you can use to strengthen your cybersecurity posture.

CIS Implementation Group- 1

In most cases, an IG1 enterprise is typically small to medium-sized with limited IT and cybersecurity expertise to dedicate towards protecting IT assets and personnel. A common concern of these enterprises is to keep the business operational, as they have a limited tolerance for downtime. IG1 defines 56 safeguards.

The sensitivity of the data that they are trying to protect is low and principally surrounds employee and financial information. Safeguards selected for IG1 should be implementable with limited cybersecurity expertise and aimed to thwart general, non-targeted attacks. These Safeguards will also typically be designed to work in conjunction with small or home office commercial off-the-shelf (COTS) hardware and software.

CIS Implementation Group- 2

IG2 is comprised 74 additional Safeguards and builds upon the 56 Safeguards identified in IG1.

The 74 Safeguards selected for IG2 can help security teams cope with increased operational complexity. Some Safeguards will depend on enterprise-grade technology and specialized expertise to properly install and configure.

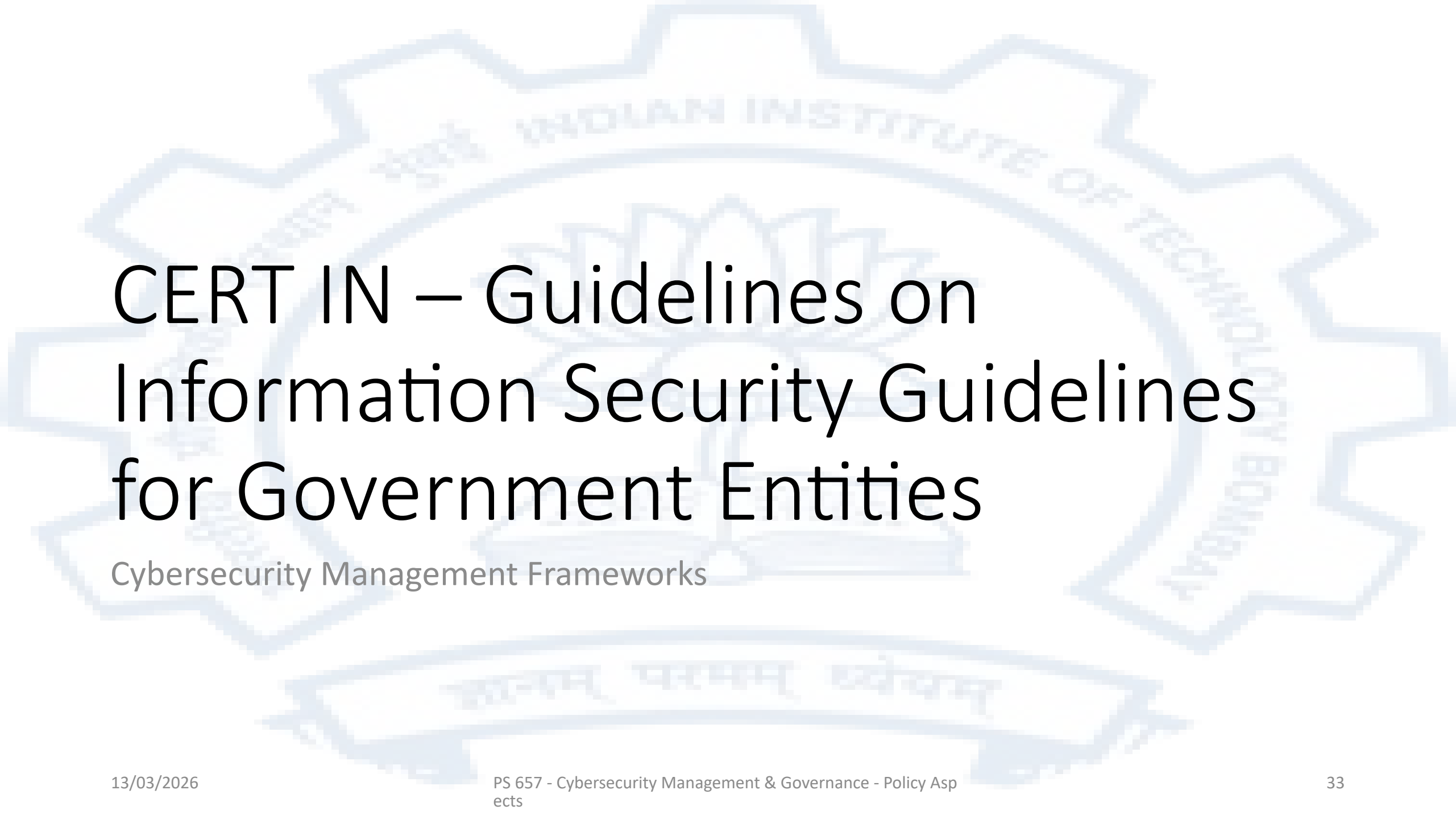
An IG2 enterprise employs individuals who are responsible for managing and protecting IT infrastructure. These enterprises typically support multiple departments with differing risk profiles based on job function and mission. Small enterprise units may have regulatory compliance burdens. IG2 enterprises often store and process sensitive client or enterprise information and can withstand short interruptions of service. A major concern is loss of public confidence if a breach occurs.

CIS Implementation Group- 3

IG3 is comprised of an additional 23 Safeguards. It builds upon the Safeguards identified in IG1 (56) and IG2 (74) totaling the 153 Safeguards in CIS Controls v8 and v8.1.

An IG3 enterprise commonly employs security experts that specialize in the different facets of cybersecurity (e.g., risk management, penetration testing, application security). IG3 assets and data contain sensitive information or functions that are subject to regulatory and compliance oversight. An IG3 enterprise must address availability of services and the confidentiality and integrity of sensitive data. Successful attacks can cause significant harm to the public welfare.

Safeguards selected for IG3 must abate targeted attacks from a sophisticated adversary and reduce the impact of zero-day attacks.



CERT IN – Guidelines on Information Security Guidelines for Government Entities

Cybersecurity Management Frameworks

Scope and Applicability

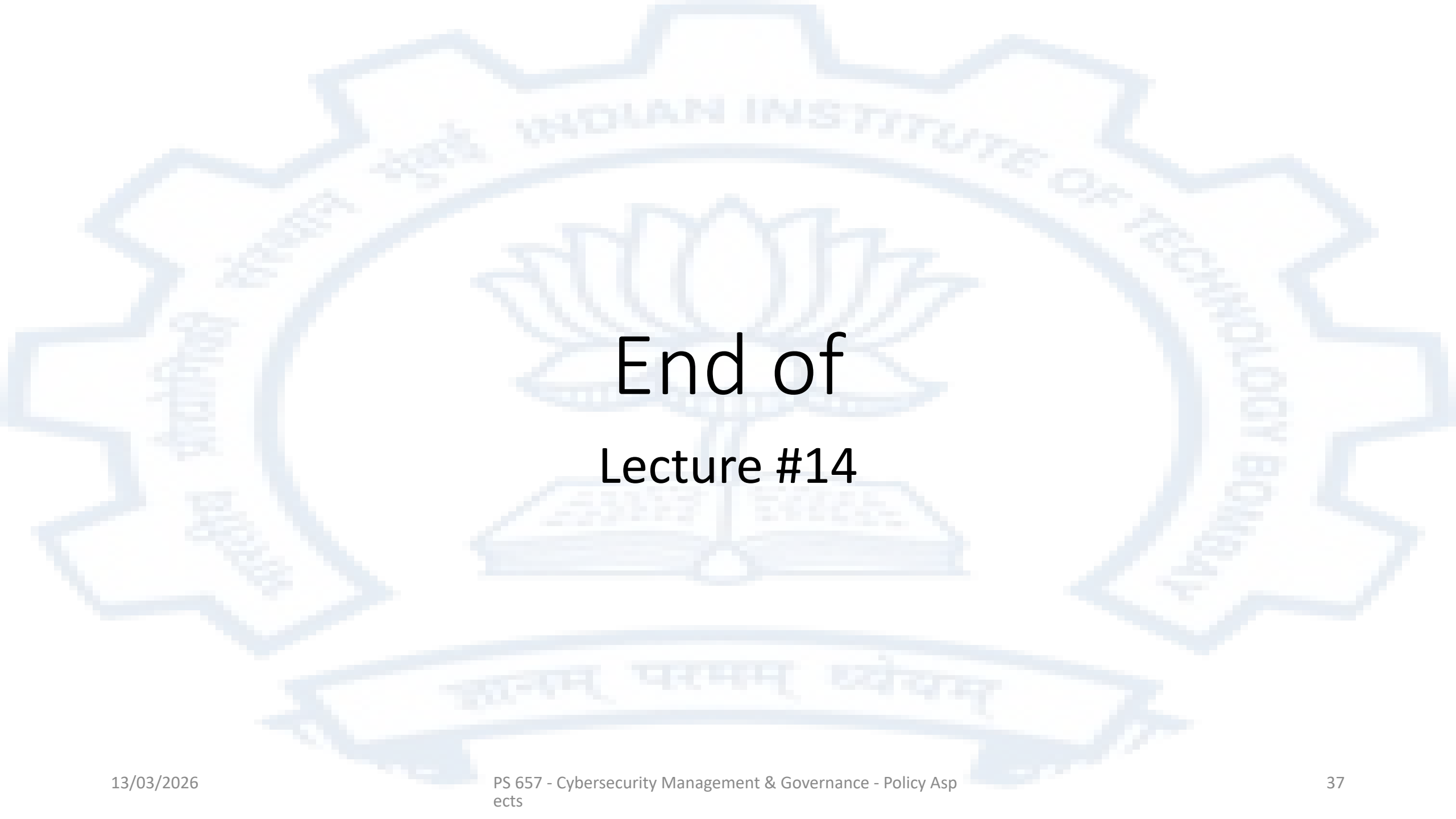
- The purpose of these guidelines is to establish a prioritized baseline of cyber security measures and controls within Central government organisations and their associated organisations. These guidelines relating to information security practices, procedures, prevention and response are issued by the Indian Computer Emergency Response Team (CERT-In) for all Ministries, Departments, Secretariats and Offices specified in the First Schedule to the Government of India (Allocation of Business) Rules, 1961, their attached and subordinate offices, and all government institutions, public sector enterprises and other government agencies under their administrative purview (hereinafter collectively referred to as “government entities”).
- Government of India has already put in place various mechanisms which are aimed at preventing cyber-attacks and also to guide organisations in responding to cyber-related incidents such as comprehensive Cyber Crisis Management Plan (CCMP) document and maturity ladder. Government entities need to mature from baseline guidelines mentioned in this document to cyber resilient entity with implementation of comprehensive CCMP. In addition to this, Government of India has also issued a Cyber Security Guidelines for Central Government CISOs and Government Employees (**Ref. Annexure 1**), which shall be mandatorily complied with by Government departments.

Table of Contents

1. Introduction and Purpose.....	5
2. Applicability and Scope.....	7
3. Policy Measures	8
4. Network and infrastructure security.....	10
5. Identity and access management.....	18
6. Application security.....	20
7. Data security.....	22
8. Third party access and Outsourcing.....	24
9. Secure Cloud Services	25
10. Hardening Procedures.....	26
11. User awareness and Training.....	30
12. Social media security.....	31
13. Vulnerability and patch management.....	32
14. Security monitoring and incident management	34
15. Security auditing guidelines.....	36
Annexure 1: Guidelines for Central Government CISOs and Employees ..	39

To summarize

- In order to cope with the complexities of technology, the legal requirements and manage risk adequately we need a framework to establish and manage cybersecurity relevant controls. There are several such frameworks
- ISO/IEC 27000 family is the most popular. The requirements are set out in 27001 and this is a requirements standard and hence is certifiable.
- ISO/IEC 27000 family is comprehensive but takes a lot of resource to establish and run. This adopts a comply or not approach
- NIST CSF defines a framework that is closer to security operations and this has a maturity model allowing for the notion that organizations can improve their cybersecurity maturity over time
- The CIS top 18 is an attempt to simplify and defines 3 implementation groups depending on the size and sophistication of the implementing organization
- CERT-IN has some simple operational guidance for government entities but this is not formulated as a framework but rather as a set of things that should be done

The background of the slide features a large, light blue watermark of the Indian Institute of Technology Bombay logo. The logo is circular with a gear-like outer border. Inside the border, the text "INDIAN INSTITUTE OF TECHNOLOGY BOMBAY" is written in a circular path. In the center of the logo is a stylized lotus flower above an open book. At the bottom of the logo, there is a banner with the Sanskrit motto "सत्यम् धर्मम् विद्यया" (Satyam Dharmam Vidhyaya).

End of Lecture #14